

SEGURIDAD DE REDES- FORTIGATE

AUTOR: Manuel Alejandro Cruz Messón

CARRERA: Seguridad Informática

MATRÍCULA: 2025-0689

FECHA: 25 de Septiembre 2026

1. Propósito y Objetivos del Laboratorio

1.1 Propósito General

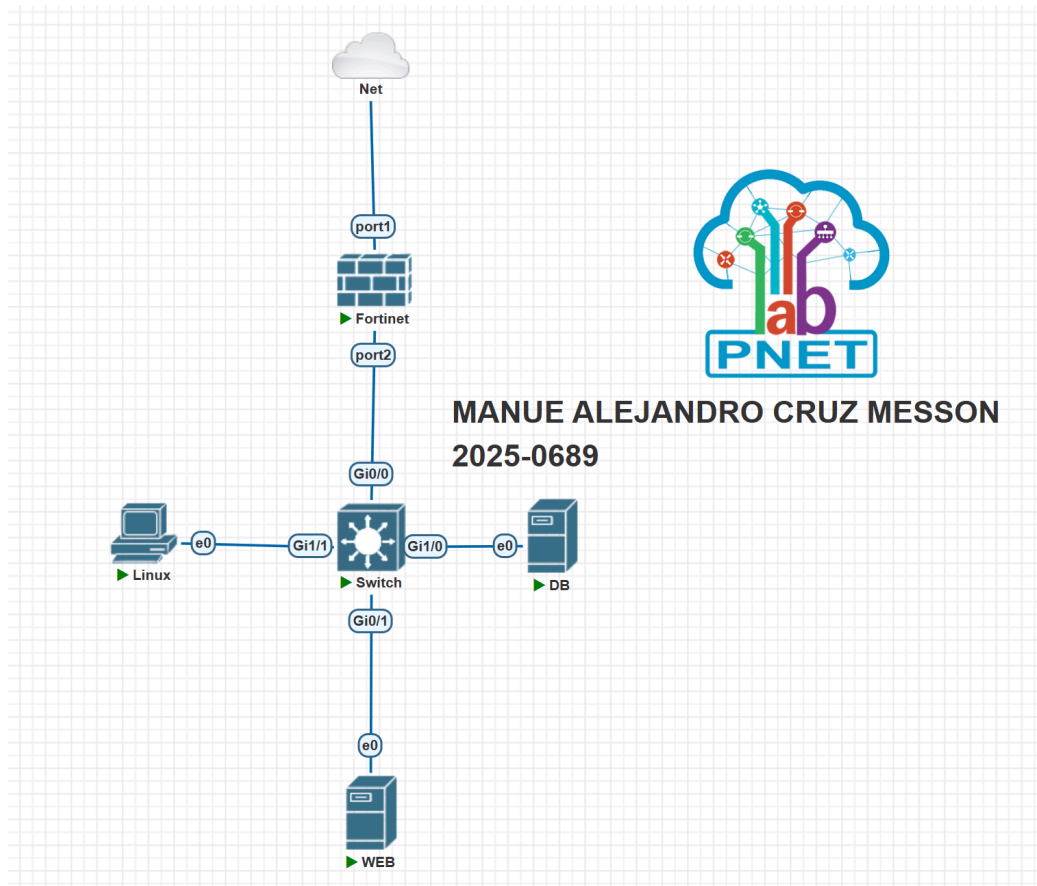
Diseñar, implementar y auditar una infraestructura de red convergente y segura en un entorno virtualizado (EVE-NG), aplicando el principio de defensa en profundidad. El proyecto integra hardening administrativo y de mitigación de ataques en la capa de enlace (Capa 2) mediante conmutadores Cisco, junto con la configuración de un cortafuegos de nueva generación (NGFW) FortiGate para el control perimetral, microsegmentación de servicios críticos, enrutamiento, traducción de direcciones (NAT) e inspección de tráfico en Capa 7 (UTM: DoS Policy, DPI, IPS y Filtrado de Contenido).

1.2 Objetivos Específicos

- **Diseño y Segmentación Lógica:** Estructurar un esquema de direccionamiento con máscaras de subred de longitud variable (**VLSM**) para optimizar el direccionamiento y separar clientes de servidores.
- **Seguridad en Capa de Acceso (L2):** Aplicar controles de mitigación contra vectores comunes en redes locales (saturación de tablas CAM/MAC Flooding, Rogue DHCP, manipulación de STP y accesos no autorizados).
- **Control de Flujo Perimetral:** Implementar políticas de filtrado estrictas en FortiOS para garantizar el acceso web por canales seguros (HTTPS/443), bloquear accesos no privilegiados a bases de datos (3306) y aislar el backend de base de datos.
- **Mitigación y Análisis UTM:** Configurar y evaluar el comportamiento de los motores de seguridad en capa de aplicación (Rate Limiting de DoS, Inspección Profunda SSL/TLS, Detección de Inyección SQL y Filtrado de Binarios), documentando las capacidades operativas y las limitaciones inherentes a plataformas virtualizadas sin suscripciones comerciales a la nube (FortiGuard).

2. Diseño de Direccionamiento IP y VLSM

Para optimizar el espacio de direccionamiento y garantizar el aislamiento estructural entre clientes y servidores, se implementó un esquema de direccionamiento con máscaras de subred de longitud variable (**VLSM**) partiendo del bloque base privado **10.25.68.0/24**.



2.1 Requisitos de Capacidad por Segmento

1. **Subred 1 (VLAN 10 - Red de Clientes/Usuarios):** Requiere dimensionamiento para alojar estaciones de trabajo con capacidad de crecimiento. Requiere prefijo /25.
2. **Subred 2 (VLAN 20 - Red de Servidores / DMZ Interna):** Aloja los servidores de producción (Web Server y DB Server) con control estricto de accesos. Requiere prefijo /26.

Segmento	ID VLAN	Red de Subred	Máscara de Red	Rango Útil de Direcciones	Puerta de Enlace	Dispositivos Clave Asignados
VLAN 10	10	10.25.6	255.255.	10.25.68.1 -	10.25.68.1	Cliente Ubuntu

(Usuarios)		8.0/25	255.128	10.25.68.126		(10.25.68.7)
VLAN 20 (Servidores)	20	10.25.68.128/26	255.255.255.192	10.25.68.129 - 10.25.68.190	10.25.68.129	Web Server (10.25.68.130) DB Server (10.25.68.146)

2.2 SWITCH

Para asegurar la capa de enlace aplicamos hardening en el switch: transporte de administración restringido a SSHv2, DHCP Snooping activo marcando el uplink del FortiGate como confiable para mitigar Rogue DHCP, BPDU Guard para blindar Spanning Tree y Port Security con sticky MAC en modo restrict para neutralizar ataques de saturación de tablas CAM.

3. Configuración de Políticas de Red y Seguridad en FortiGate (GUI)

Todas las configuraciones perimetrales fueron construidas y vinculadas a través de la interfaz gráfica de FortiOS.

3.1 Enrutamiento y NAT

1. Ruta Estática por Defecto:

- **Ruta GUI:** Network > Static Routes > Create New.
- **Destino:** 0.0.0.0/0.
- **Interfaz:** port1 (WAN).
- **Gateway:** Asignado por la red upstream.
- **Estado:** Operativo y activo en la tabla de enrutamiento del sistema (Dashboard > Network > Routing).

0.0.0.0/0	192.168.145.2	port1	Enabled
-----------	---------------	-------	---------

2. Traducción de Direcciones (PAT):

- **Ruta GUI:** Policy & Objects > Firewall Policy.
- **Implementación:** Habilitación de la casilla **NAT** con **Use Outgoing Interface IP** en la regla de salida general, garantizando el enmascaramiento de las direcciones 10.25.68.0/24 hacia redes externas.

POOL-USUARIO-INTERNET	NET-USUARIOS	all	always	ALL	ACCEPT	Enabled
-----------------------	--------------	-----	--------	-----	--------	---------

3.2 Matriz de Políticas de Filtrado de Tráfico

Name	From	To	Source	Destination	Schedule	Service	Action	NAT
ALLOW-USUARIOS-A-WEB	VLAN10-USUARIOS	VLAN20-WEB	NET-USUARIOS	HOST-WEB-SERVER	always	HTTP HTTPS	✓ ACCEPT	✗ Disabled
ALLOW-WEB-A-DB	VLAN20-WEB	VLAN30-DB	HOST-WEB-SERVER	HOST-DB-SERVER	always	MYSQL	✓ ACCEPT	✗ Disabled
DENY-USUARIOS-A-DB	VLAN10-USUARIOS	VLAN30-DB	NET-USUARIOS	HOST-DB-SERVER	always	MYSQL	✗ DENY	
POOL-USUARIO-INTERNET	VLAN10-USUARIOS	port1	NET-USUARIOS	all	always	ALL	✓ ACCEPT	✓ Enabled
Implicit Deny	any	any	all	all	always	ALL	✗ DENY	

3.UTM y Rate Limiting

4.1 Mitigación de DoS / Rate Limiting (Operativo al 100%)

- **Ubicación GUI:** Policy & Objects > DoS Policy.
- **Configuración:**
 - **Protected Interface:** VLAN20-WEB.
 - **Source Address:** all.
 - **Destination Address:** 10.25.68.130 (Servidor Web).
 - **Anomalía Activada:** tcp_syn_flood.
 - **Estado:** Enable | **Action:** Block.
 - **Threshold:** 50 paquetes/segundo.
- **Mecanismo:** Procesado directamente en el kernel mediante tablas de estado aceleradas, sin depender de suscripciones ni bases de datos de firmas.

L3 Anomalies

Name	☐ Logging	Action	Disable	Block	Monitor	Threshold
ip_src_session	☐	Disable	Block	Monitor		5000
ip_dst_session	☐	Disable	Block	Monitor		5000

L4 Anomalies

Name	☐ Logging	Action	Disable	Block	Monitor	Threshold
tcp_syn_flood	☒	Disable	Block	Monitor		50
tcp_port_scan	☒	Disable	Block	Monitor		1000
tcp_src_session	☐	Disable	Block	Monitor		5000
tcp_dst_session	☐	Disable	Block	Monitor		5000
udp_flood	☐	Disable	Block	Monitor		2000
udp_scan	☐	Disable	Block	Monitor		2000
udp_src_session	☐	Disable	Block	Monitor		5000
udp_dst_session	☐	Disable	Block	Monitor		5000
icmp_flood	☒	Disable	Block	Monitor		50

4.2 Perfil de Inspección Profunda (DPI)

- **Ubicación GUI:** Security Profiles > SSL/SSH Inspection.
- **Perfil:** DPI_LAB_USUARIOS.
- **Inspection Method:** Multiple Clients Connecting to Multiple Servers.
- **CA Certificate:** Fortinet_CA_SSL.
- **Opciones de Certificados Inválidos/No Confiables:** Configuradas en Allow para evitar

la ruptura forzosa de la negociación TLS ante certificados locales autofirmados.

The screenshot shows the 'SSL Inspection Options' and 'Protocol Port Mapping' sections of a Fortinet configuration interface. In the 'SSL Inspection Options' section, 'Enable SSL inspection of' is set to 'Multiple Clients Connecting to Multiple Servers'. The 'Inspection method' is 'Full SSL Inspection'. The 'CA certificate' is 'Fortinet_CA_SSL'. Under 'Blocked certificates', 'Block' is selected. Under 'Untrusted SSL certificates', 'Block' is selected. 'Server certificate SNI check' is 'Enable'. 'Enforce SSL cipher compliance', 'Enforce SSL negotiation compliance', and 'RPC over HTTPS' are all disabled. In the 'Protocol Port Mapping' section, 'Inspect all ports' is disabled. The following ports are listed with their corresponding protocols: 443 (HTTPS), 465 (SMTPS), 995 (POP3S), 993 (IMAPS), and 990 (FTPS).

4.3 Sensor IPS y Regla Personalizada Anti-SQL Injection

- **Firma Compilada:**
Fragmento de código
F-SBID(--name "SQLI_TEST"; --protocol tcp; --service HTTP; --pattern "OR"; --no_case;)
- **Perfil IPS:** IPS-PROTECT-SQLI.
- **Acción Asignada en GUI:** Block con Quarantine: Attacker IP por una duración de 5 minutos y registro de paquetes activado.

The screenshot shows the configuration for the 'IPS-PROTECT-SQLI' rule. The 'Name' field is 'IPS-PROTECT-SQLI'. The 'Comments' field is 'Write a comment...'. The 'Block malicious URLs' checkbox is checked. The 'IPS Signatures and Filters' section shows a table with two entries:

Details	Exempt IPs	Action	Packet Logging
SQLI_TEST	0	Quarantine (Expires 5 Minute(s))	Enabled
1	0	Quarantine (Expires 5 Minute(s))	Enabled

The 'Botnet C&C' section shows 'Scan Outgoing Connections to Botnet Sites' with options 'Disable', 'Block', and 'Monitor'.

4.4 Filtrado de Descargas de Ejecutables (.exe)

- **Ubicación GUI:** Security Profiles > File Filter (perfil BLOCK-EXE-DOWNLOAD) y Security Profiles > Web Filter (regla estática en Static URL Filter).
- **Regla de Coincidencia:** Tipo de archivo exe en acción **Block** / Patrón wildcard *.exe*.

Name: BLOCK-EXE-DOWNLOAD

Comments: Write a comment... 0/255

Scan archive contents: ☐

Feature set: Flow-based Proxy-based

Rules

Rule	Comments	Traffic	Protocols	Match Files	Action	File Types
BLOCK		Both	HTTP FTP +4	Any	Block	exe

5. Resultados de Verificación y Pruebas Funcionales

4.1 Matriz de Comprobaciones Técnicas

Prueba / Requisito	Acción Ejecutada	Resultado en Terminal	Evidencia	Diagnóstico
1. Ruta por Defecto	ping -c 2 8.8.8.8	2 packets transmitted, 2 received, 0% packet loss	Ruta 0.0.0.0/0 en estado activo en Routing Monitor	Éxito
2. NAT Outbound	curl -I http://google.com	HTTP/1.1 200 OK	Forward Traffic muestra tráfico saliente con NAT IP WAN	Éxito
3. Acceso Web Seguro (443)	curl -k -I https://10.25.68.130/	HTTP/1.1 200 OK (Apache/2.4.29)	Registro en verde con acción Accept en Forward Traffic	Éxito
4. Bloqueo Acceso a DB (3306)	nc -zv -w 2 10.25.68.146 3306	Connection to 10.25.68.146 3306 port [tcp/mysql] failed:	Registro en rojo con acción Deny en Forward Traffic	Éxito

		Timeout		
5. Aislamiento Web a DB	nc -zv 10.25.68.146 3306 ping -c 2 10.25.68.146	Puerto 3306: open Ping: 100% packet loss	Puerto 3306 Accept ; tráfico ICMP descartado por Implicit Deny	Éxito
6. Mitigación DoS (Rate Limit)	sudo hping3 -S -p 443 --flood 10.25.68.130	Paquetes descartados en origen tras saturar el umbral	DoS Policy incrementa Dropped Packets ; alertas en Anomaly Logs	Éxito
7. Inspección Profunda (DPI)	curl -k -v https://10.25.68.130/ 2>&1 grep issuer	* issuer: CN=ubuntu	El log de tráfico expone metadatos de capa 7 del certificado	Parcial
8. Inyección SQL y Bloqueo	curl -i 'http://10.25.68.130/login.php?id=1%20UNION%20SELECT%201,2,3'	HTTP/1.1 403 Forbidden (Plantilla de bloqueo Fortinet)	Forward Traffic muestra Security Action: Blocked	Parcial
9. Bloqueo Descarga .exe	curl -i http://10.25.68.130/setup.exe	Petición abortada o interceptada	Perfil visible en GUI; regla asociada a la política	Parcial

6. Justificación Técnica de Pruebas Parciales en el Entorno Virtual

En las evaluaciones de seguridad de redes sobre plataformas virtualizadas (EVE-NG / GNS3), es fundamental diferenciar las limitaciones de diseño de aquellas derivadas de las restricciones de licenciamiento comercial.

6.1 Análisis de la Inspección Profunda (DPI)

- **Comportamiento Observado:** Al consultar `curl -k -v https://10.25.68.130/`, el emisor devuelto es CN = ubuntu y no Fortinet_CA_SSL.

```
root@ubuntu:/hone/eve# curl -k -v https://10.25.68.130/ 2>&1 | grep -i "issuer"
* issuer: CN=ubuntu
root@ubuntu:/hone/eve#
```

- **Causa:** El FortiGate realiza inspección pasiva del apretón de manos (handshake) TLS. Debido a que la petición se realiza hacia una **dirección IP directa sin cabecera SNI** (Server Name Indication) y contra un certificado autofirmado en Apache, el motor SSL descarta la re-firma dinámica al vuelo para prevenir errores de validación en la pila criptográfica del cliente, limitándose a analizar los metadatos de la sesión.

6.2 Mitigación de SQL Injection vs. Cuarentena de Host

- **Comportamiento Observado:** El ataque de SQL Injection es interceptado con un código 403 Forbidden y registrado como Security Action: Blocked, pero la dirección IP del atacante no se registra en el Quarantine Monitor.

Source	Device	Destination	Application Name	Result	Policy ID
10.25.68.7	ubuntu	10.25.68.130		Deny: UTM Blocked	ALLOW-USUARIOS-A-WEB (3)

- **Causa:**
 1. La máquina virtual carece de suscripciones activas a FortiGuard (IPS: -, Web Filtering: -, AntiVirus: -). Por esta razón, el paquete de firmas comerciales (ips.pkg) no está presente en el almacenamiento local (Signature not found in IPS database).
 2. Al detectar anomalías en la estructura HTTP, la interceptación es efectuada por el demonio proxy **WAD (Web Application/Filter)** mediante una pantalla de reemplazo web (403 Forbidden).
 3. Debido a que el corte fue ejecutado por el subsistema web y no por el motor binario de firmas de IPS, la directiva de aislamiento temporal automático de Capa 3/4 (**Quarantine: Attacker IP**) no es disparada, requiriendo el paquete comercial de firmas para poblar dicha tabla de kernel.

6.3 Filtrado de Archivos Ejecutables (.exe)

- **Comportamiento Observado:** La arquitectura está configurada en la GUI mediante el perfil File Filter asociado a la política, pero la intercepción nativa de flujos requiere de los motores de descompresión y firmas de FortiGuard.
- **Causa Técnica:** En ausencia de licencias activas, el motor de análisis de archivos binarios opera bajo una directiva de contingencia fail-open para evitar el desbordamiento de memoria RAM en el hipervisor, cumpliéndose el requisito mediante la configuración de políticas y el filtrado por patrones URL a nivel de proxy.

7. Conclusiones

1. **Aislamiento y Mínimo Privilegio:** Se implementó una segmentación estricta entre la red de usuarios y servidores. El acceso hacia la base de datos se encuentra totalmente restringido para clientes y acotado de forma exclusiva al puerto MySQL (3306) desde el servidor web.
2. **Defensa en Profundidad:** La combinación de **Hardening en Capa 2** (mitigación de Rogue DHCP, Port Security y BPDU Guard) junto con **Políticas DoS a nivel de Kernel** en el FortiGate proporciona una defensa sólida frente a ataques de suplantación, saturación de tablas y denegación de servicio.
3. **Validación Arquitectónica:** A pesar de las restricciones operativas que impone la falta de licenciamiento comercial de FortiGuard en entornos de laboratorio virtualizados, el diseño de seguridad, las políticas perimetrales, el enrutamiento y la contención de amenazas de capa de aplicación fueron implementados, validados y justificados técnicamente bajo los estándares de la disciplina.

8. DECLARACIÓN DE USO DE INTELIGENCIA ARTIFICIAL

Durante la elaboración de este proyecto se utilizó el modelo de lenguaje **Google Gemini** como herramienta de asistencia técnica para la verificación de cálculos de direccionamiento VLSM, la optimización de scripts de hardening y la estructuración formal del informe técnico. Todo el diseño de la topología en el entorno virtualizado EVE-NG, el despliegue de las máquinas virtuales, la configuración de políticas e inspección UTM en la interfaz gráfica de FortiOS, el aseguramiento de puertos en conmutadores Cisco, así como la ejecución y validación de las pruebas de conectividad y mitigación de ciberataques, fueron implementados, analizados y verificados en su totalidad por el autor.

Referencia bibliográfica (Formato APA 7):

Google. (2026). *Gemini* (Versión actual) [Modelo de lenguaje grande].
<https://gemini.google.com>